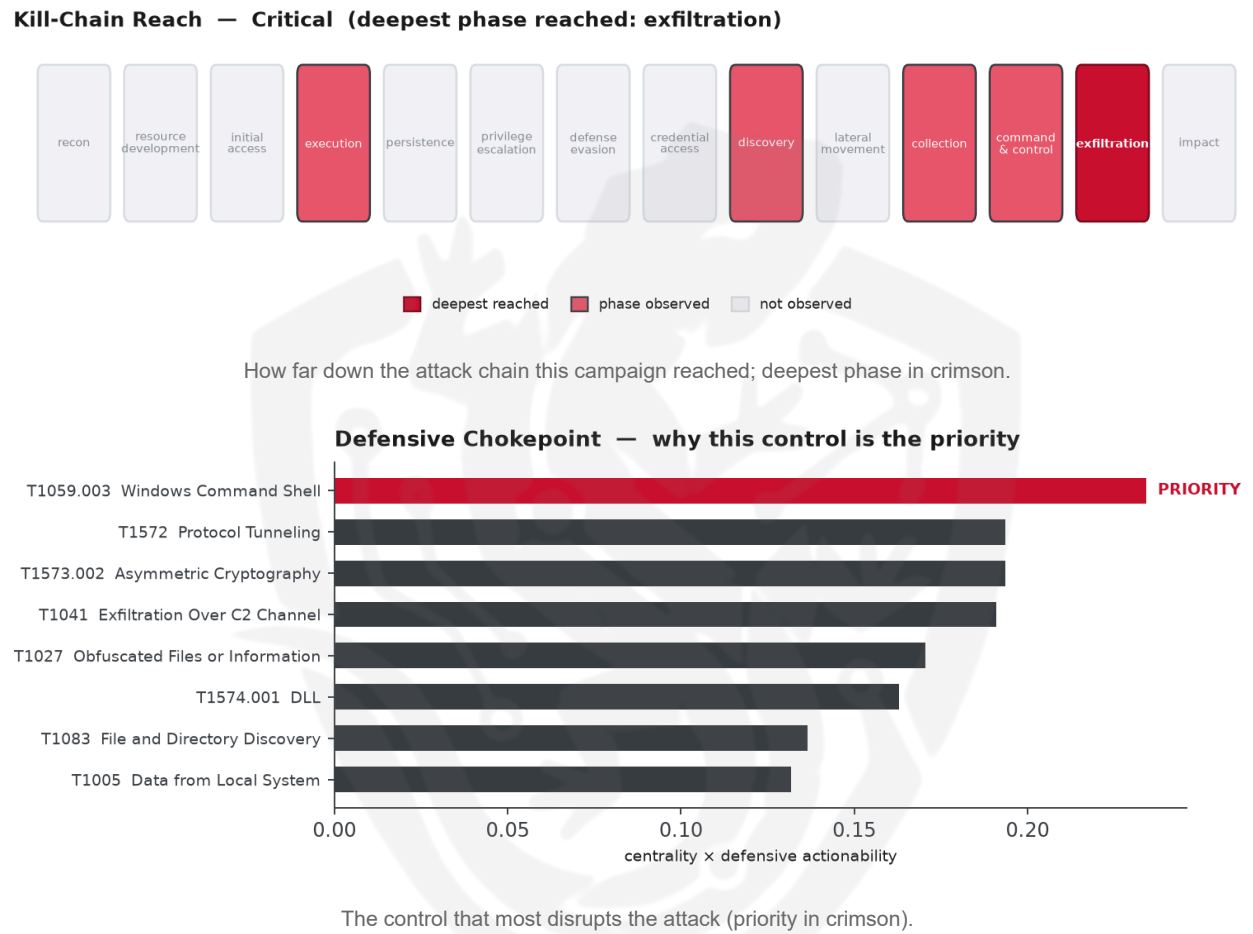


THREAT REPORT: TORTOISESHELL

Visual Summary



Summary

This brief covers activity involving TWOSTROKE, with no single central CVE identified, affecting United States of America, Australia, Belgium, Canada, Japan, Saudi Arabia, United Arab Emirates, United Kingdom of Great Britain and Northern Ireland, Defense, Aerospace, Technology. The source attributes this activity to Tortoiseshell. The operational risk is assessed as Critical. Priority should be given to the control described below, centred on T1059.003 Windows Command Shell.

Threat Overview

The activity is associated with Tortoiseshell. Malware observed: TWOSTROKE. Reported victimology: United States of America, Australia, Belgium, Canada, Japan, Saudi Arabia, United Arab Emirates, United Kingdom of Great Britain and Northern Ireland, Defense, Aerospace, Technology.

Attack Chain and Priority Control

The source records the following techniques: - T1132.001 Standard Encoding - T1036.005 Match Legitimate Resource Name or Location - T1574.001 DLL - T1082 System Information Discovery - T1005 Data from Local System - T1572 Protocol Tunneling - T1083 File and Directory Discovery - T1041 Exfiltration Over C2 Channel - T1027 Obfuscated Files or Information - T1573.002 Asymmetric Cryptography - T1059.003 Windows Command Shell - T1070.004 File Deletion - T1071.001 Web Protocols - T1105 Ingress Tool Transfer - T1090.001 Internal Proxy

Priority should be given to T1059.003 Windows Command Shell. Recommended control: Constrain PowerShell for unprivileged users (Constrained Language Mode + AppLocker); enable script-block logging; block wscript/cscript where unneeded.

Technical Appendix

Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.

Observed Techniques (ATT&CK, expert-tagged by source)

- T1132.001 Standard Encoding
- T1036.005 Match Legitimate Resource Name or Location
- T1574.001 DLL
- T1082 System Information Discovery
- T1005 Data from Local System
- T1572 Protocol Tunneling
- T1083 File and Directory Discovery
- T1041 Exfiltration Over C2 Channel
- T1027 Obfuscated Files or Information
- T1573.002 Asymmetric Cryptography
- T1059.003 Windows Command Shell
- T1070.004 File Deletion
- T1071.001 Web Protocols
- T1105 Ingress Tool Transfer
- T1090.001 Internal Proxy

Analytical Scores

- Priority technique (graph chokepoint): T1059.003 Windows Command Shell (centrality 0.2928).
- Operational risk: Critical (score 0.968, reaches exfiltration).

Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.5016; reference threshold $\tau = 0.6$).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

Historical Profile	Behavioural Overlap
Tropic Trooper	0.5016
APT18	0.4915
BRONZE BUTLER	0.4654
Velvet Ant	0.4494
Metador	0.4307

Enrichment Signal

- Highest AbuseIPDB confidence among IOCs: 0%.

Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

Type	Indicator
Domain	locat[.]sbs
Domain	tiktok-u[.]sbs

Flame Cell // Adversary Pivot [BETA]

BETA. A hypothetical tabletop projection, anchored to documented ATT&CK behaviour and technique co-occurrence across 170 tracked groups. It is not a prediction; treat it as a war-game prompt and review before acting. Spot a pivot that looks wrong? norbert@salacti.com

- **Control applied:** T1059.003 Windows Command Shell (execution)
- **Observed here:** T1059.003 Windows Command Shell was the execution control point here; the pivot is drawn from Tortoiseshell's own documented ATT&CK repertoire.
- **Projected pivot:** T1204 User Execution (execution)
- **Basis:** documented in Tortoiseshell's own ATT&CK repertoire, and disproportionately paired with Windows Command Shell across tracked groups (lift 1.1, ~1.1x base rate). Their move, not a generic one.

With T1059.003 Windows Command Shell blocked, Tortoiseshell could preserve the same objective by pivoting to T1204 User Execution, a technique from Tortoiseshell's documented repertoire. Defensive countermeasure: Block execution of downloaded HTA/JS/LNK; enforce mark-of-the-web; disable Office macros from the internet; user awareness on lures.

Detection and hardening for the pivot (T1204 User Execution)

- **Telemetry:** Endpoint process telemetry; Email/proxy logs
- **Detect:**
 - User double-clicking archive/ISO/LNK contents that spawn interpreters
 - Mark-of-the-Web on delivered files; LOLBIN execution from user temp paths
- **Harden:**
 - Block risky file types; ASR rules; user awareness training
 - Application control to stop execution from user-writable directories
- **MITRE:** M1049 Antivirus/Antimalware, M1038 Execution Prevention, M1017 User Training · DS0009 Process, DS0022 File

